PRÁCTICA 5 - VULNERABILIDADES

Realizado por Unai García Blanco y Alberto García Martín

1. Comentar brevemente las funcionalidades de al menos tres de las webs que se proponen y qué organismos/empresas/asociaciones las mantienen. 2
- Hispasec 2
- NVD 3
- Incibe 4

2. Elegir y comentar brevemente alguna de las noticias recogidas en la sección "una-al-día" de Hispasec Sistemas, justificando la decisión de la elección. 5

3. Documentar qué son y para qué sirven CVE y CVSS en relación a las vulnerabilidades. Comparar y encontrar las principales diferencias entre las versiones v2 y v3. 6
- CVE (Common Vulnerabilities and Exposures) 6
- CVSS (Common Vulnerability Scoring System) 6

4. Localizar un bug de algún sistema en alguna de las páginas indicadas en la primera actividad, del que haya un exploit disponible. Haga un resumen indicando el CVE, el programa afectado, la versión, el nivel de gravedad, una breve descripción del fallo, e incluya el código del exploit. 8

5. Comentar brevemente las páginas encontradas en la búsqueda de páginas dedicadas a la publicación de vulnerabilidades. 9
- Exploit Database 9
- Packet Storm Security 9
- Full Disclosure 9
- CERT/CC 9
- VulnDB 9

6. Describir el proyecto OWASP y el subproyecto OWASP Top Ten. Comentar cómo han evolucionado los 3 riesgos de seguridad más importantes en aplicaciones web. 10
- OWASP 10
- OWASP Top Ten 10

1. **Comentar brevemente las funcionalidades de al menos tres de las webs que se proponen y qué organismos/empresas/asociaciones las mantienen.**

Vamos a comentar las funcionalidades de cada una de las siguientes webs:

- **Hispasec**

Ampliamente reconocida por su labor divulgativa y su compromiso por mejorar la seguridad informática, Hispasec presenta una serie de funcionalidades generales:

- ➔ ***Boletines diarios:*** la más conocida son las hojas informativas conocidas como “Una-al-día”, proporcionan información actualizada sobre vulnerabilidades, amenazas emergentes, ataques y avances en el ámbito de la ciberseguridad. Estos boletines resultan extremadamente valiosos para los administradores de sistemas o profesionales de la seguridad para mantenerse al tanto de los eventos relacionados con la seguridad informática.
- ➔ ***Análisis técnico y accesible:*** los boletines ofrecen análisis claros y detallados, abordan vulnerabilidades tanto desde el punto de vista técnico como práctico.
- ➔ ***Amplia cobertura:*** la web incluye información sobre fallos de seguridad del software, aplicaciones web, sistemas operativos y redes, además de tendencias generales y recomendaciones de seguridad.
- ➔ ***Archivo histórico:*** la web proporciona un archivo histórico que permite consultar todos los boletines pasados. Esto es útil como recurso para investigaciones o estudios retrospectivos sobre la ciberseguridad.

La empresa principal que lo mantiene es ***Hispasec Sistemas,*** una empresa española fundada en 1998, con sede en Málaga, especializada en la ciberseguridad. Esta empresa está dedicada a la consultoría en seguridad informática, auditorías de seguridad, desarrollo de soluciones personalizadas para la protección de sistemas y redes y la formación en ciberseguridad.



- **NVD**

NVD (National Vulnerability Database) es ampliamente reconocida como una herramienta esencial para la gestión de vulnerabilidades, especialmente en grandes organizaciones y empresas que requieren de información precisa y centralizada sobre amenazas de seguridad.
Las principales funcionalidades de NVD son:

- ➔ ***Base de datos centralizada de vulnerabilidades:*** la web recopila y organiza las vulnerabilidades conocidas en el ámbito global, identificadas mediante el estándar CVE (Common Vulnerabilities and Exposures). Cada una de estas entradas proporciona los detalles técnicos sobre la vulnerabilidad.
- ➔ ***Motor de búsqueda avanzado:*** permite realizar búsquedas específicas en criterios como el nombre del producto o fabricante, la severidad de la vulnerabilidad o las fechas de publicación/modificación. Esto facilita encontrar la información relevante de manera rápida para los administradores y desarrolladores.
- ➔ ***Sistema de puntuación de severidad (CVSS):*** cada vulnerabilidad es evaluada mediante el Common Vulnerability Scoring System, una escala de gravedad de las vulnerabilidades. Ofrece una estandarización que ayuda a priorizar la mitigación de riesgos.
- ➔ ***Información complementaria:*** NVD también proporciona enlaces a soluciones, parches o guías de mitigación de las vulnerabilidades documentadas.
- ➔ ***Actualizaciones frecuentes:*** la base de datos se mantiene actualizada con nuevas vulnerabilidades, lo que garantiza que los usuarios estén al tanto de los riesgos más recientes.

El principal organismo que mantiene la web es el ***Instituto Nacional de Estándares y Tecnología (NIST)***, una agencia del Departamento de Comercio de los Estados Unidos. NIST es responsable de establecer estándares y guías técnicas en múltiples disciplinas, incluida entre ellas la ciberseguridad. Proporciona una referencia confiable y gratuita para organizaciones y profesionales de todo el mundo.

- **Incibe**

Incibe es una referencia clave en España para la gestión de vulnerabilidades y el fortalecimiento de la ciberseguridad a nivel nacional. Destaca por su compromiso por la prevención, detección y resolución de incidentes. Las principales funcionalidades son:

- ➔ ***Buscador de vulnerabilidades:*** ofrece un buscador que permite localizar vulnerabilidades específicas relacionadas con productos, servicios y software. Incluye detalles técnicos para cada vulnerabilidad (Identificación CVE, descripción del problema, impacto en el sistema afectado, soluciones disponibles…).
- ➔ ***Información categorizada:*** las vulnerabilidades son clasificadas por tipo de software, sistemas afectados o nivel de criticidad, facilitando la priorización de los administradores en cuanto a sus esfuerzos de protección.
- ➔ ***Alertas de seguridad y recomendaciones:*** publican alertas periódicas sobre amenazas emergentes, ataques en curso y buenas prácticas de ciberseguridad, así como una serie de guías para implementar soluciones a problemas conocidos.
- ➔ ***Apoyo a empresas y ciudadanos:*** INCIBE no solo recopila información y publica vulnerabilidades, también se enfoca en sensibilizar y educar a usuarios mediante campañas de concienciación, herramientas y recursos gratuitos para mejorar la seguridad y formaciones y seminarios especializados.
- ➔ ***Soporte en incidentes:*** a través de su CERT (Equipo de Respuesta a Emergencias de Seguridad Informática), INCIBE ayuda a gestionar incidentes de seguridad en empresas y administraciones públicas.

El organismo que lo mantiene es el propio ***Instituto Nacional de Ciberseguridad INCIBE.*** Es una entidad pública dependiente del Ministerio de Asuntos Económicos y Transformación Digital del Gobierno de España. Su misión es garantizar la seguridad de los ciudadanos, empresas y administraciones públicas en España. Trabaja en colaboración con organismos internacionales, como la Unión Europea y otros centros de ciberseguridad, para unificar esfuerzos en la lucha contra las amenazas informáticas.

2. Elegir y comentar brevemente alguna de las noticias recogidas en la sección “una-al-día” de Hispasec Sistemas, justificando la decisión de la elección.

La noticia que hemos escogido es la siguiente:

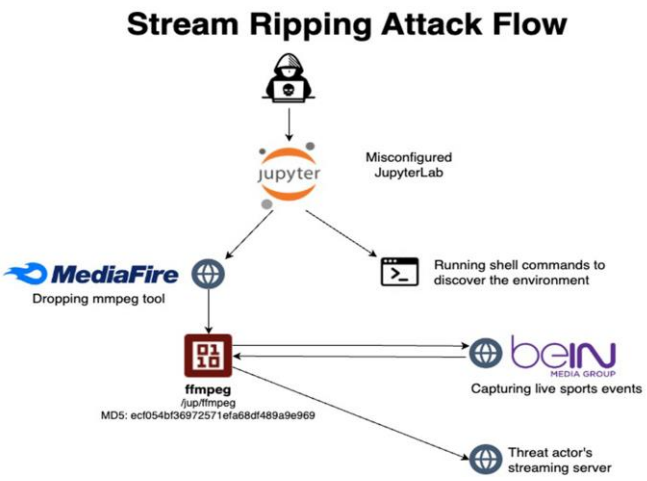
https://unaaldia.hispasec.com/2024/11/ciberdelincuentes-consiguen-emitir-retransmisiones-deportivas-ilegales-a-traves-de-cuadernos-jupyter-no-seguros.html

Hemos elegido esta noticia debido a que es un tema candente en la actualidad y que da mucho de qué hablar debido a que recientemente se está intentando batallar contra las retransmisiones ilegales en España.

La noticia relata un método innovador pero ilegal que ciberdelincuentes están empleando para **retransmitir eventos deportivos sin autorización**. Están aprovechando la exposición de cuadernos Jupyter, herramientas diseñadas para el desarrollo y análisis de datos, como plataformas para transmitir contenido deportivo pirateado. Esta actividad no solo infringe derechos de autor, sino que también pone en riesgo los sistemas de usuarios que inadvertidamente ofrecen acceso público a sus cuadernos.

Los cuadernos Jupyter, frecuentemente empleados en contextos educativos y de investigación, permite a los usuarios ejecutar código directamente desde un navegador web. Por su diseño están configurados para ser accesos rápidos y flexibles, sin embargo, esta flexibilidad puede convertirse en un riesgo si no se toman medidas de seguridad adecuadas.

Los atacantes buscan instancias de Jupyter Notebook accesibles públicamente, que a menudo no tienen configurada ninguna contraseña o autenticación robusta. Una vez acceden al entorno, despliegan software malicioso e invaden el cuaderno en un servidor para retransmitir eventos deportivos en directo. Esto implica que el hardware y el ancho de banda del propietario son utilizados sin su consentimiento.



Los expertos en seguridad recomiendan tomar las siguientes precauciones para proteger los entornos Jupyter: configurar contraseñas seguras, limitar el acceso público, tener el software Jupyter actualizado regularmente y monitorizar el entorno.

3. Documentar qué son y para qué sirven CVE y CVSS en relación a las vulnerabilidades. Comparar y encontrar las principales diferencias entre las versiones v2 y v3.

- **CVE (Common Vulnerabilities and Exposures)**

CVE es un sistema de identificación y nomenclatura estándar para vulnerabilidades de seguridad. Cada vulnerabilidad identificada recibe un número único denominado CVE-ID, que permite a los desarrolladores, investigadores y organizaciones referirse a la misma vulnerabilidad de manera uniforme, facilitando la comunicación y coordinación.

CVE sirve para:

- ➔ ***Identificación única:*** permite que diferentes bases de datos, herramientas y servicios reconozcan la misma vulnerabilidad sin ambigüedades.
- ➔ ***Seguimiento y gestión:*** ayuda a priorizar y gestionar vulnerabilidades en entornos complejos.
- ➔ ***Referencia centralizada:*** mantenido por MITRE, en colaboración con socios internacionales, se usa en sistemas de evaluación como NVD (National Vulnerability Database).

- **CVSS (Common Vulnerability Scoring System)**

CVSS es un sistema estándar que permite medir la gravedad de las vulnerabilidades de software en función de características técnicas y de impacto. Proporciona una puntuación numérica (de 0 a 10) acompañada de categorías cualitativas como “Bajo”, “Medio” o “Crítico”.

CVSS sirve para:

- ➔ ***Evaluación de riesgo:*** ayuda a las organizaciones a comprender el impacto potencial de una vulnerabilidad.
- ➔ ***Priorización de esfuerzos:*** facilita la decisión sobre cuáles vulnerabilidades abordar primero.
- ➔ ***Comparación estándar:*** proporciona un marco común para comparar la gravedad de diferentes vulnerabilidades.

Las principales diferencias entre CVSS v2 y v3 se centran en la precisión, el contexto y las categorías utilizadas para describir y medir vulnerabilidades:

ASPECTO	CVSS v2	CVSS v3
Escalas y métricas	Tres métricas principales: Base, Temporal y Ambiental.	Métricas más detalladas: Base, Temporal, Ambiental y Contextual.
Impacto contextual	No considera el impacto del entorno específico donde ocurre la vulnerabilidad.	Introduce el concepto de “Scope” (alcance), evalúa si el impacto se extiende más allá del sistema afectado.
Escalado del impacto	Impactos categorizados como “Confidencialidad”, “Integridad” y “Disponibilidad”.	Mejora las categorías con niveles “Ninguno”, “Bajo” y “Alto” para una granularidad más precisa.
Puntuación crítica	Las puntuaciones son más conservadoras y tienden a infravalorar vulnerabilidades complejos.	Proporciona una mejor evaluación de vulnerabilidades críticas, como las que afectan múltiples sistemas.
Usabilidad	Más simple, pero menos flexible para casos avanzados.	Más compleja, pero capaz de adaptarse a situaciones y contextos específicos.

4. **Localizar un bug de algún sistema en alguna de las páginas indicadas en la primera actividad, del que haya un *exploit* disponible. Haga un resumen indicando el CVE, el programa afectado, la versión, el nivel de gravedad, una breve descripción del fallo, e incluya el código del *exploit*.**

Hemos localizado un bug desde la página NVD, ahora vamos a analizar sus características y a proporcionar el código del exploit:

https://nvd.nist.gov/vuln/detail/CVE-2019-9053

Características del bug encontrado	
CVE	CVE-2019-9053
Programa afectado	CMS Made Simple.
Versión vulnerable	2.2.8
Nivel de gravedad	8.1 (Alto) según CVSS v3.
Descripción del fallo	Vulnerabilidad de inyección SQL basada en tiempo en el módulo News, explotable a través de la manipulación del parámetro m1_idlist en URLs específicas. Esto permite a atacantes remotos ejecutar consultas SQL maliciosas sin necesidad de autenticación, obteniendo acceso a información sensible de la base de datos.

Podemos encontrar el código del exploit en una de sus muchas webs de referencia en las que se mantenga el apartado “exploit”:

https://packetstormsecurity.com/files/152356/CMS-Made-Simple-SQL-Injection.html
https://www.exploit-db.com/exploits/46635

5. Comentar brevemente las páginas encontradas en la búsqueda de páginas dedicadas a la publicación de vulnerabilidades.

Se han encontrado 5 páginas más relacionadas con la publicación de vulnerabilidades:

- **Exploit Database**

Recurso mantenido por Offensive Security, es una de las bases más populares de exploits. Su enfoque está en exploits prácticos que los investigadores pueden utilizar para probar vulnerabilidades en entornos controlados. Incluyen scripts, instrucciones y exploits listos para usar, además de sus correspondientes detalles técnicos.

- **Packet Storm Security**

Ofrece una amplia gama de recursos de seguridad, entre ellos exploits, herramientas y documentación técnica. Es conocido por ser una fuente confiable para vulnerabilidades y exploits detallados. También incluye herramientas de prueba de penetración y análisis de seguridad.

- **Full Disclosure**

Lista de correos que permite a investigadores y profesionales compartir información técnica sobre vulnerabilidades, a menudo antes de que sean corregidas. Es una plataforma útil para la obtención de información detallada y muchas veces inmediata sobre problemas emergentes.

- **CERT/CC**

El Equipo de Respuesta a Emergencias Informáticas (CERT Coordination Center) proporciona reportes detallados sobre vulnerabilidades y ofrece guías de mitigación. Es una fuente confiable y útil para incidentes complejos y críticos.

- **VulnDB**

Base de datos comercial que ofrece información ampliada sobre invulnerabilidades, incluyendo las no registradas en bases de datos como CVE. Está enfocada en dar un valor adicional a empresas que necesitan una cobertura más extensa.

6. Describir el proyecto OWASP y el subproyecto OWASP Top Ten. Comentar cómo han evolucionado los 3 riesgos de seguridad más importantes en aplicaciones web.

- **OWASP**

El proyecto OWASP (Open Web Application Security Project) es una comunidad global sin ánimo de lucro dedicada a mejorar la seguridad del software. Sus objetivos principales incluyen educar a desarrolladores, organizadores y profesionales en prácticas seguras de desarrollo de aplicaciones y proporcionar herramientas, documentación y recursos gratuitos.

Algunos de los proyectos más destacados de OWASP han sido:

- ➔ ***OWASP Top Ten:*** lista de los principales riesgos de seguridad en aplicaciones web.
- ➔ ***OWASP ASVS (Application Security Verification Standard):*** marco para evaluar la seguridad en las aplicaciones.
- ➔ ***ZAP (Zed Attack Proxy):*** herramienta gratuita para realizar pruebas de seguridad automatizadas.

- **OWASP Top Ten**

OWASP Top Ten es uno de los muchos subproyectos dentro de OWASP que enumera los diez principales riesgos de seguridad en aplicaciones web. Es conocido como un estándar global de referencia en la industria de la ciberseguridad. La lista es actualizada de forma periódica para reflejar las amenazas emergentes, basándose en datos recopilados de miles de organizaciones y aplicaciones. La lista más reciente fue publicada en 2021, e incluye los siguientes riesgos:

1. A01: Broken Access Control (Control de acceso roto).
2. A02: Cryptographic failures (Fallos criptográficos).
3. A03: Injection (Inyección).
4. A04: Insecure Design (Diseño inseguro).
5. A05: Security Misconfiguration (Mala configuración de seguridad).
6. A06: Vulnerable and Outdated Components (Componentes vulnerables y obsoletos).
7. A07: Identification and Authentication Failures (Fallos de identificación y autenticación).
8. A08: Software and Data Integrity Failures (Fallos en la integridad de software y datos).
9. A09: Security Logging and Monitoring Failures (Fallos de registro y monitoreo de seguridad).
10. A10: Server-Side Request Forgery (SSRF).

Los 3 riesgos más importantes de seguridad de los previamente mencionados son:

- A01: Broken Access Control (Control de Acceso Roto).
- A02: Cryptographic Failures (Fallos criptográficos).

- A03: Injection (Inyección).

Vamos a explicar ahora la evolución de estos tres riesgos de seguridad:

EVOLUCIÓN DE LOS TRES RIESGOS DE SEGURIDAD MÁS IMPORTANTES		
RIESGO	**ANTES**	**AHORA**
A01. Control de acceso roto	Conocido como “Insecure Direct Object References (IDOR)” y “Missing Function Level Access Control”.	Consolidado como el principal riesgo en el OWASP Top Ten 2021 debido a su prevalencia y el impacto crítico que puede llegar a ocasionar.
A02. Fallos criptográficos	Conocido como “Sensitive Data Exposure”.	Se centra más en el mal uso o ausencia de mecanismos criptográficos.
A03. Inyección	Siempre ha sido un riesgo clave desde la primera edición del OWASP Top Ten.	Aunque sigue siendo prominente, el uso de ORM y mecanismos de seguridad automatizados ha reducido su prevalencia.